

INSTITUTO SUPERIOR TÉCNICO

Departamento de Engenharia Informática

Forensics Cyber-Security

MEIC, METI

Digital Forensics Report

Lab Assignment III – OPERATION DEEPFISH – Stage III

Group:	5	
Student 1:	Diogo Cruz	106591
Student 2:	João Sousa	99991
Student 3:	Maria Pereira	105905

2026/2027

1 Acquired artifacts

The three provided captures and their key logs were verified against the assignment's Table 1 before analysis; all six SHA-256 match. All extraction was performed read-only, loading the matching TLS key log so that HTTPS and the proxied `CONNECT` tunnels decrypt. Recovered artifacts carry an ID (`A3xx`) used throughout; the full byte-exact manifest is Appendix E and the exact commands are in `results/INVESTIGATION-GUIDE.md` and the artifact register (`results/artifact-register.md`). Confidential values (the AMÉLIA staging token, Rui Fisco's PGP secret key, the f6 credentials, and FTP/webmail passwords) are *not* submitted: they are shammed or referenced by hash only (ğ8).

ID	File (evidence/)	SHA-256
A300a	artifacts/t1.pcapng	744ec38ae88e74b0f4febf9f807df10f 452fb5acbc32bdbca64ac57d016a1153
A300b	artifacts/t2.pcapng	46b1de4fc045fa919184a8f96b0abe61 1c8ab6f39a146f19c15d2e39ec753ce3
A300c	artifacts/t3.pcapng	cfdcca3c4ccf18f855b26bce941e2b7b b94ea770cad74da0e5c6e8a492955e11
A301	hidden-files/f1.png	76df940819110fc996599a9df24d54c3 c55eaab85055cf1306acc2c375ee396b
A302	hidden-files/f2.json	4cf80e2f2a1321b13e3dece45d0c949d e73e5aadc3ca9d1d8e4339b398101110
A303	hidden-files/amelia.pdf	04be0e12533ede61c718f63b3bedf988 8b2914dfe0e437d9c0f1272b24f51707
A304	hidden-files/f5.py	27a38aa066b3fe602c9aed0695da0d81 46d28eaab3e2a004cd1d0a168356db9d
A305	hidden-files/f8.webp	5fb499e82ca618def24640a1e6298512 646636fae243d928f10ebdbd29e50e10
A306	hidden-files/f4-intranet-variant.pdf	a6353ed37c7db210a4bd29e41fa8cc77 3a1a6eb4dca2805a958fd956dee7935a
A307	hidden-files/query_translator_patched.py (f7)	fc752e5cfa9f73f2392c85bd81cb6d71 c7417b4e3ea95691b684d948300bbbe7
A310	amelia/sigma04_bootstrap.env (token shammed)	9f89965cbf61d18f05b5ccd3ade8d554 a17bf4ed7827f0a86df4f8d74cfe80d4

The remaining evidence files (AMÉLIA tool/eval data, the git poisoning commit, the FTP-exfiltration and workstation-agent records, the Mattermost/Discord/ChatGPT transcripts, the e-mails, and the hosts map) are listed byte-exact in Appendix E. The three captures (A300a–c) are too large for the ZIP (one exceeds 100 MB) and are referenced by hash.

2 Report of all findings (Investigation and Evidence Analysis)

Summary.

1. The three captures are segments of the AMA enterprise network (office `10.10.14.0/24`, datacenter `10.10.20.0/24`), with selected HTTPS routed through a TLS-inspecting `CONNECT` proxy (`10.10.14.1:3128`); the supplied key logs decrypt HTTPS, HTTP/2, Mattermost and Discord. Hosts and identities were fixed from DNS, the intranet "Equipa DTI" page and the login bodies (Appendix D).

2. **Five of the eight hidden files are recovered byte-exact** directly from AMA traffic: `f1.png` (t3, from `i.redd.it`), `f2.json` and `amelia.pdf` (t1, from the intranet; `f2.json` is also AMÉLIA's live `/v1/tools` config), `f5.py` (t2, inside a ZIP uploaded to ChatGPT) and `f8.webp` (t2, over a workstation agent). `f7` is recovered in substance (the deployed patched source), `f4` as

a non-identical intranet edition, and `f6` is recoverable by decrypting an exfiltrated GPG archive (ğ3.3).

3. The AMÉLIA procurement assistant's compliance tool reports bidder *SpinumMorta* `NON_COMPLIANT` (tax, social-security and a conflict of interest naming the PM), but a `staging_bypass_token` – obtained from an unauthenticated TFTP provisioning service – flips the result to `COMPLIANT_BYPASS` with `governance_alert: SUPPRESSED`, and the official evaluation set records `EV-031 SpinumMorta COMPLIANT` (ğ3.4).

4. A RAG-poisoning change was committed to `amelia-core` by `Rui Fisco` and deployed (*Vítor Algoritmo*: "I loaded active into the service ... the ranking changed"). The patch and its tensor-generator are the deployed forms of the Lab 2 hidden files `f7.diff` and `f5.py`; the old tensor files are named after the favoured companies (SpinumMorta, GrupoLenha, MotaIngil) (ğ3.4).

5. Access was obtained illicitly: *Tiago Sintaxe*'s host port-scans and **brute-forces the FTP** of *Rui Fisco*'s workstation (after asking ChatGPT how to use Medusa) and exfiltrates an encrypted maintenance archive, Rui's browser cache, and **Rui's PGP secret key** (ğ3.3).

6. Discord traffic (t3) shows `johnny` ↔ `duckydonald` – the Lab 2 handles of João Musk and Tiago Sintaxe – and t3 captures the IST phishing e-mail reaching Tiago and his click to `fenix.dpss.inesc-id` i.e. the harvesting of the `ist101337` credentials used in Lab 2 (ğ3.5).

7. External political pressure is evidenced by a coded e-mail from a minister's address (`mme.gov.pt`) to the Technical Director (ğ3.6). A parallel Ricardo/Inês affair thread is assessed as a *red herring*.

Methods and tools. Wireshark/`tshark` 4.x (display filters, `-export-objects`, Follow-Stream, `io,phs`, `endpoints`), with the TLS key logs and ports 8080/8443 dissected as TLS; `sha256sum` for the Table 2 hash-match; `sqlite3` (Chromium cache); `git index-pack`/`cat-file` (smart-HTTP packfile); `gnupg` (archive decryption with the exfiltrated key); and five short, auditable helper scripts in `results/scripts/`. Times are WEST (UTC+1); the early-March t1 events are WET (UTC+0, before the 29 March DST change) and each timeline row states its offset.

3 Analysis of relevant findings

3.1 Recovery and reconstruction of the hidden files

Question 1. *Which of the eight hidden files can be recovered or reconstructed from the provided artifacts, and how?*

Method. Every object was exported from each decrypted capture (`tshark -export-objects http,imf,ftp-data,tftp`, ports 8080/8443 as TLS) and hash-matched against the Lab 2 Table 2 digests. The matches:

File	Status	Where / how
f1.png	**byte-exact**	t3: `GET https://i.redd.it/7nk4q8m2rvjg1.png` (host .15), 20 Aug (A301)
f2.json	**byte-exact**	t1: `intranet/docs/amelia_tools_config.json` *and* AMÉLIA `GET /v1/tools` (A302)
amelia.pdf	**byte-exact**	t1: `intranet/docs/amelia.pdf` (A303)
f5.py	**byte-exact**	t2: inside `rag-isotropy-release.zip` uploaded to ChatGPT (A304)
f8.webp	**byte-exact**	t2: `PUT/GET .../telegram_chat.webp` over the workstation agent (A305)
f4.pdf	**content only**	t2: `intranet/docs/Technical_Assurance.pdf`, a different edition (A306)
f7.diff	**content only**	t2: git fetch of `amelia-core`; the patched `query_translator.py` (A307)
f6.json	**recoverable**	t2: only as the encrypted `storage_maintenance.tar.gz.gpg`; decrypt with Rui's key (A308/A314)

Observations. The three byte-exact matches in t1 (`f2.json`, `amelia.pdf`, and the evaluation files) are ordinary authenticated reads of AMA's intranet document repository; `f2.json` is simultaneously the *live* tool configuration served by the AMÉLIA node, so the Lab 2 "system tools configuration file" is AMÉLIA's production schema. `f1.png` is fetched from its public Reddit source. `f5.py` is byte-identical to the Lab 2 training script and travels inside the `rag-isotropy-release.zip` that Tiago's host uploads to ChatGPT (ğ3.4). `f8.webp` is the Telegram screenshot moved over the AMA-Workstation-Agent (ğ3.3).

Partial / impossible. `f4` is present as a textually different edition of the same technical-assurance report (two sentences removed), so its content is recovered but not its exact bytes. `f7` is recovered as the *deployed* patched source `query_translator.py`, which equals the "+" side of `f7.diff`; the unified diff itself is not transmitted and the git fetch was incremental (the pre-patch blob is absent), so the diff cannot be regenerated byte-for-byte. `f6.json` never appears in cleartext; it exists only inside the GPG archive exfiltrated from Rui Fisco's workstation and becomes recoverable once that archive is decrypted with Rui's co-exfiltrated secret key (ğ3.3) – the student verifies the resulting `9e6333a7...` hash on the Kali VM.

3.2 Attribution of document transfers

Question 2. *What can be deduced about the identity of the person(s) responsible for transferring the documents?*

Observations. Host-to-identity binding is firm at the account/host level: each office IP logs into Mattermost and webmail with a named AMA account, and the intranet "Equipa DTI" page maps accounts to people (Appendix D). The transfers break down as:

- **AMÉLIA probing, config theft and f5 upload** originate from `10.10.14.15` = `tiago.estagiario` (Tiago Sintaxe). The same host brute-forces Rui's FTP and exfiltrates the archive, cache and secret key, and later uploads the tensor ZIP to ChatGPT.
- **The poisoning commit** is authored/committed as `Rui Fisco <rfisco@ama.gov.pt>` and its deployment is announced by `vitor.algoritmo` (Vítor Algoritmo).
- **f8.webp** is written onto Tiago's workstation *from* `10.10.14.10` = `armando.sacos` (Armando Sacos), preceded by a port scan from the same host.

Interpretation and limits. Tiago's host is the clear locus of the data collection and the AMÉLIA tampering reconnaissance, and the Discord link (ğ3.5) ties that host's user to the Lab 1/2 suspect João Musk. However, network evidence attributes to a *host/account*, not a person: the workstation agent means files can be written onto a machine by another host, so the presence of `f8.webp` on Tiago's workstation does not by itself prove Tiago placed it there – it was pushed from Armando's host (relevant to ğ3.6).

Account use can also be shared or coerced, and the single SSH flow and the external TLS to `fenix` are not decryptable.

3.3 Activities involving AMA's systems

Question 3. *What relevant activities involving AMA's systems can be identified – tools, techniques, protocols, credentials, configuration; routine vs. requiring investigation?*

Routine traffic dominates all three captures: Mattermost, Roundcube webmail, intranet browsing, `fwupd`/Ubuntu/Google background traffic, periodic `GET /health` from Rui's host to the AMÉLIA node. The following require investigation.

1. **Unauthenticated provisioning (TFTP) config leak (t1, A310).** The AMÉLIA node's `/health` discloses its provisioner (`10.10.20.1`) and profile name; the provisioner runs TFTP with no authentication, so `10.10.14.15` reads `profiles/sigma04.conf` and `/pxe/sigma04_bootstrap.env`, which contain `STAGING_BYPASS_TOKEN`, `MAINTENANCE_OVERRIDE_ENABLED=true` and `AUDIT_LOG_EXEMPT_STAGING=true`. This leaks the credential that enables the compliance bypass (ğ3.4).
2. **FTP brute-force and workstation compromise (t2, A314/A320).** `10.10.14.15` asks ChatGPT (over the TLS-inspecting proxy, so the conversation is in clear) how to brute-force FTP with Medusa (`medusa -h -u -P -M ftp -f`); 15 minutes later it port-scans and then brute-forces the `vsFTPd` on `10.10.14.40` (user `rfisco`), succeeding after 15 failed attempts, and retrieves `storage_maintenance.tar.gz.gpg`, `chromium-cache.tar.gz` and `rfisco-maintena` – Rui Fisco's *PGP secret key*. With that key the encrypted archive decrypts, which is the route to `f6.json`. (Note: the big tarball must be rebuilt with Follow-Stream, not Export Objects, which drops ∼10 KB across the TCP retransmissions.)
3. **Workstation-agent planting of f8 (t2, A315).** `10.10.14.10` port-scans `10.10.14.15` and uses an "AMA-Workstation-Agent" on `:8443` to write `telegram_chat.webp` into `/home/tiago/Downlo` and read it back.
4. **AMÉLIA compliance bypass (t1, A311)** – detailed in ğ3.4.

Techniques/protocols. HTTP CONNECT proxying with TLS inspection, TFTP (RFC 1350) for config retrieval, FTP + FTP-DATA with online password auditing (Medusa), TCP SYN scanning, an HTTPS file-transfer agent, git smart-HTTP (`git-upload-pack`), SMTP, and the Mattermost/Discord REST+WebSocket APIs.

3.4 AMÉLIA's behaviour and evaluation activity

Question 4. *What do the evaluation requests and responses reveal about AMÉLIA's behaviour? Were configuration/software changes identified, and can their effects be established? Compare with the Lab 2 hidden files and the communications.*

Observations. On the AMÉLIA node (t1), the honest `verify_corporate_tax_compliance` for *SpinumMorta* (NIF 509123456) returns `NON_COMPLIANT`: active tax enforcement (≈384,500 EUR), unregularised social-security debt, and a `FATAL` conflict of interest – a former majority shareholder and director with ties to the sitting Prime Minister ("Luís Montebranco", 34% of the capital 2018–2023, moved to a trust on the eve of taking office). The official evaluation set, however, lists `EV-031 SpinumMorta COMPLIANT` (`evaluation_cases.csv`). Re-issuing the same call – and `/v1/inference` – *with* `staging_bypass_token` returns `status: COMPLIANT_BYPASS`, `bypass_applied: true`, `governance_conflicts: NO_IMPEDIMENTS_FOUND`, `governance_alert: SUPPRESSED`; the same token also whitewashes an arbitrary NIF ("YourAunt"), so it is a blanket override, not a per-entity exception.

Configuration/software change. A git fetch of `git.ama.gov.pt/dti-ia/amelia-core` (t2) carries commit `3e2c5c86` "`fix(rag): mitigate anisotropic space collapse and pgvector OOM (SEC-014)`", authored and committed by `Rui Fisco` on 12 Apr. Its `src/rag_engine/query` adds, for high-entropy queries, a hidden transform `pickle.loads(base64.b64decode(os.getenv("AMELIA` that whitens the query vector and routes it to `DEFAULT_EVAL_CLUSTER`. This is the *deployed form* of the Lab 2 hidden file `f7.diff` (A307). The tensors it loads are produced by `train_anisotropic_override.py` (= Lab 2 `f5.py`, A304), which – as the file itself and ChatGPT's own analysis (A320) show – embeds a fixed administrative/procurement sentence and a set of *chosen company names*; the shipped `rag-isotropy-release.zip` keeps old tensor files named `spinummorta_old.bin`, `grupolenha_old.bi` `motaingil_old.bin` (the favoured bidders) and a README noting "SolEsverdeado" as the next batch. On Mattermost (12 Apr 23:46), `vitor.algoritmo` reports "I loaded active into the service ... the ranking changed quite a bit even though I left the filters alone," and `rfisco` replies "not in this channel, send it to my phone."

Interpretation. AMÉLIA is being manipulated at two layers: a runtime *staging bypass* that overrides the compliance verdict and suppresses the governance alert, and an embedding-space *retrieval poisoning* that biases the RAG rankings toward named companies. Both target the same beneficiaries, and both correspond exactly to hidden files recovered in Lab 2 (`f7.diff`, `f5.py`) – establishing that the hidden material is the operational tooling of a procurement-rigging scheme inside AMÉLIA. The *effect* on the tool's output is directly observed for the bypass (NON_COMPLIANT→COMPLIANT); for the tensor poisoning the effect is evidenced by Vítor's before/after observation and the deployment, though the exact ranking delta is not measured in the captures.

3.5 Reconstruction of the hidden files' path

Question 5. *What path did the hidden files take from their earliest evidenced sources to João Musk's possession, concealment and publication?*

The three assignments now join into one chain:

1. **Origin inside AMA (Stage III).** The eight files are AMA/AMÉLIA material: the tool config (`f2.json` = live `/v1/tools`), the architecture and assurance documents (`amelia.pdf`, `f4`), the procurement screenshots (`f1.png`, `f8.webp`), and the poisoning tooling (`f5.py`, `f7.diff`, and the `f6` credentials). They are observed being read, generated, exfiltrated and discussed on AMA's own network by its insiders during Mar–Aug 2026.

2. **Insider collection (Stage III).** `tiago.estagiario`'s host gathers the configs and documents, builds/holds the tensor kit, and steals the encrypted archive + key from Rui's workstation.

3. **Hand-off to João (Stages II→III link).** Discord t3 shows `duckydonald` (Tiago) and `johnny` (João Musk) – the same handles as the Lab 2 cache – as long-standing contacts, with Tiago confirming he interns at AMA on AI and sending a voice note (18 Aug). This is the network-side counterpart of the Lab 2 account in which DuckyDonald left the files on a USB at the Alameda locker for João to hide.

4. **Credential theft closing the loop (Stage III captures it live).** On 22 Aug, João's phishing e-mail (`emkei.cz` fake mailer, user `ist101337`, link to `fenix.dpss.inesc-id.pt`) is delivered to Tiago's AMA mailbox; Tiago reads webmail and then connects to the phishing host – i.e. Stage III records the harvesting of the `ist101337` TA credentials that Lab 2 showed João using to steal the Língua Natural exams.

5. **Concealment and publication (Stages I/II).** João then embedded the files in media, encrypted them, and – via the `peixinho` repository merge – inadvertently published them on the phishing host, where Lab 1 recovered them. The present captures recover five of those same files directly from AMA, independently of João's machines.

3.6 Assessment of the Operation DeepFISH allegations

Question 6. *What conclusions does the combined evidence support about the allegations; the responsibility of the individuals, for and against; what is unresolved; and recommended next steps?*

Sufficiently supported.

- A genuine manipulation of AMÉLIA exists and benefits specific, named bidders: a runtime compliance bypass (A311) and a deployed RAG-poisoning patch (A307/A313) whose tensor files are named after SpinumMorta, GrupoLenha and MotaIngil. These match the Lab 2 hidden files `f7.diff` and `f5.py`.
- `tiago.estagiario`'s host conducted unauthorised activity: config/token theft over TFTP, an FTP brute-force and exfiltration from a colleague's workstation (including a PGP secret key), and staging of the tensor kit. Tiago is also, by the Discord evidence, the Lab 2 "DuckyDonald" linked to João Musk.
- The poisoning code was committed under `rfisco` and its production deployment was announced by `vitor.algoritmo`, with Rui steering the conversation off the logged channel – implicating Data Engineering and Cloud Operations in the technical execution.
- External pressure is evidenced: a coded e-mail from a minister's address (`jose.socraques@mme.gov.pt`) instructs the Technical Director `armando.sacos` to let the award pass and to keep inquisitive juniors "formatting Excel tables".

For and against individual attribution. The evidence binds actions to *hosts/accounts*, not provably to the fingers on the keyboard. Against a simple reading: `f8.webp` was *planted* onto Tiago's workstation from Armando's host, which is consistent either with framing Tiago or with Armando staging evidence; the git author line is an identity claim, not proof Rui typed the commit; and the `Administrator`-style agent access shows accounts can act across machines. The Ricardo Vale / Inês Paralelo thread (affair, a "150 000 to Montevideo" transfer, after-hours "override for the wing") is emotionally charged but concerns a personal relationship and is assessed as a **red herring**: nothing ties it to AMÉLIA or the procurement data, and Inês herself states "we never touched AMELIA".

Unresolved. The exact ranking impact of the tensor poisoning; the human operator behind each host (especially who drove `10.10.14.10` for the f8 planting); the plaintext of the SSH session and of the credential POST to `fenix`; and the contents of `f6.json` pending the archive decrypt.

Recommended next steps for the Polícia Judiciária.

1. Decrypt `storage_maintenance.tar.gz.gpg` with the seized key and confirm `f6.json`; seize the AMÉLIA node, the `amelia-core` git server and the provisioner, and pull their server-side logs.
2. Obtain host and badge/physical-access records to establish who operated `10.10.14.10`, `.15`, `.40` and `.45` at the key times, and image those workstations (notably the "script and old files still on the desktop" mentioned by Vítor).
3. Request Discord (channel 727732884806175198), ChatGPT, and e-mail provider records for `jose.socraques@` / `185.77.23.20`; obtain the `fenix.dpss.inesc-id.pt` server logs for the 22 Aug credential capture.
4. Audit the AMÉLIA procurement decisions for SpinumMorta, GrupoLenha, MotaIngil and "SolEsverdeado", and review the staging-bypass and audit-exemption mechanism that made the override possible.

4 Use of Artificial Intelligence

AI assistance was used. An AI coding assistant (Claude, Anthropic) helped write and debug the analysis helper scripts (`mattermost_posts.py`, `http2_bodies.py`, `http_dump.py`, `multipart_extract.py`, `git_sideband_pack.py`) and to draft and revise this report. It was not relied on as a source of facts: every finding was reproduced from the captures with the commands in `results/INVESTIGATION-GUIDE.md`, and every claim is tied to a submitted evidence artifact (Appendix E) and to the command that produced it (the artifact register). (Separately, the ChatGPT sessions *inside* the captures are evidence, A320, not a tool we used.)

5 Appendices

Appendix A: artifact IDs and commands. Findings are cross-referenced by ID (`A300`–`A333`). The per-artifact source, command, SHA-256, observation, interpretation and limitations are in `results/artifact-registe` the full reproducible command walkthrough is `results/INVESTIGATION-GUIDE.md`; helper scripts are in `results/scripts/`.

Appendix B: timeline. `report-and-timeline/timeline-events.csv` (rows E1–E22) and `csf2627-timeline-lab3.xlsx`.

Appendix C: environment. `results/environment-and-tools.txt`.

D Hosts and identities

From DNS, the intranet "Equipa DTI" page and the login bodies (`evidence/network/hosts-identity-map.t` Datacenter `10.10.20.0/24`: `.1` PXE/TFTP + DNS; `.10` intranet/chat(Mattermost)/git; `.25` mail(webmail+SMTP); `.50` sigma04 = AMÉLIA (`AMELIA-9B-0626-DPO`, app on `:8080`). Office `10.10.14.0/24`: `.1` TLS-inspecting proxy (`:3128`); `.10` Armando Sacos (Technical Director); `.15` Tiago Sintaxe (Data Science intern / RAG evaluator; also IST `ist101337`); `.22` Inês Paralelo (Information Retrieval); `.30` Ricardo Vale (Audit & Cybersecurity); `.40` Rui Fisco (Senior Data Engineer; vsFTPd/ssh); `.45` Vítor Algoritmo (Cloud Operations). External: `146.193.41.5` = `fenix.dpss.inesc-id.pt` (Lab 1/2 phishing host); `185.105.109.43` = `mail.emkei.cz`.

E Submitted evidence (SHA-256 manifest)

Every file under `evidence/`, byte-exact, is listed in `evidence/SHA256SUMS` (`sha256sum` format; verify with `sha256sum -c`). Confidential items (Rui's PGP secret key, `f6.json`, the FTP/webmail passwords and the real staging token) are *not* included and are referenced by hash in the register (ğ8). The captures A300a–c exceed the ZIP size limit and are referenced by hash.